API Sentinel

Apps Workflow Guide

14 applications · End-user steps · Features · Key points · OWASP mapping

01	API Validator Pro	Live capture + parameter fuzzing
02	Auth Validator Pro	Valid vs invalid vs missing token replay
03	APISphere	Manual API client (Postman-style)
04	Method Tampering	Alternate HTTP verbs on the same endpoint
05	Soft Delete	Delete then re-read resource checks
06	IDOR Tester	Cross-user object ID swap
07	Params Tamper	Targeted parameter mutation
08	Swagger Scan	Static OpenAPI / Swagger audit
09	RSQL Tester	RSQL / FIQL filter injection
10	API Scan	Active multi-module vulnerability scan
11	File Upload	Malicious & edge-case upload suite
12	XSS Test	Reflected XSS payload probing
13	JS Analyser	Secrets · PII · infra in API traffic
14	LLM / Command Injection	OS command + LLM prompt injection fuzzing

1. API Validator Pro

Live capture + parameter fuzzing

USAGE

Use when you need to discover real APIs from a running web/mobile flow and check whether parameters accept invalid, boundary, or type-wrong values.

OWASP / SECURITY

API4:2023 Unrestricted Resource Consumption · API8:2023 Security Misconfiguration · input-validation / injection surface

FEATURES

- Live capture via mitmproxy + system proxy
- HAR / cURL import
- Auto param detection (body + query) with types
- Positive / negative datasets + unique formats
- Results by HTTP status · CSV/HTML export

KEY POINTS

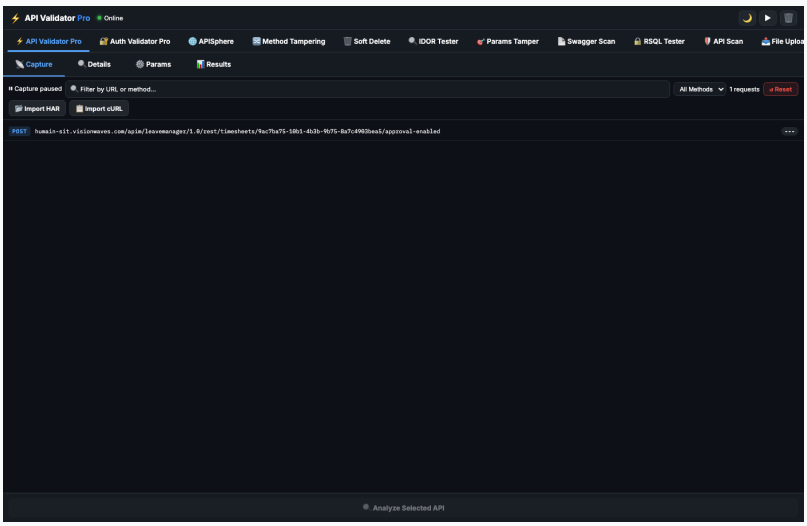
- Best starting point for unknown APIs — capture first, then test.
- Prefer one high-value API + key params over “select all”.
- POS ≈ expected 2xx; NEG ≈ expected 4xx — APIs that return 200 on bad input still look like FAIL.

USER WORKFLOW (follow in order)

1. Open API Validator Pro from the top tool bar.
2. Click Start Capture, then use the target app normally in the browser.
3. When needed APIs appear, Stop Capture (or keep capturing).
4. Select request(s) — or Import HAR / paste cURL.
5. Click Analyze Selected API → review detected params and types.
6. Tick params to test; set unique formats / custom cases if needed.
7. Click Run Tests → open Results and review Pass / Fail / status.
8. Export CSV or HTML report.

LANDING PAGE

Tool UI as shown in API Sentinel



2. Auth Validator Pro

Valid vs invalid vs missing token replay

USAGE

Use to verify APIs actually enforce authentication — replay the same calls with a good token, a bad/expired token, or no Authorization header.

OWASP / SECURITY

API2:2023 Broken Authentication · API5:2023 Broken Function Level Authorization

FEATURES

- Capture / HAR / cURL intake
- Modes: Authorized · Unauthorized · No auth
- Batch replay with live progress
- Status summary (2xx / 4xx / 5xx / errors)
- CSV / HTML export

KEY POINTS

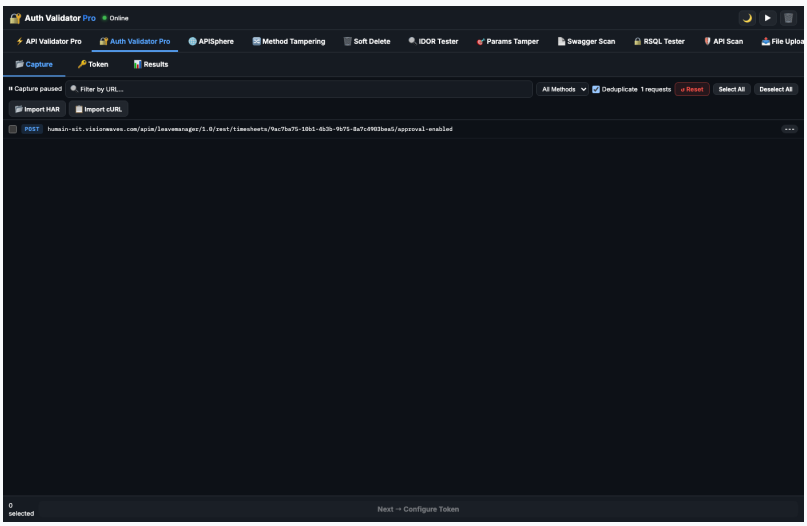
- Unauthorized (or No auth) + HTTP 2xx on a protected API = high-signal finding.
- Use the Results filters to isolate 2xx under unauth modes.
- Paste Bearer token without the word “Bearer” if the UI adds it.

USER WORKFLOW (follow in order)

1. Open Auth Validator Pro.
2. Capture traffic or Import HAR / cURL; select APIs.
3. Click Next → Configure Token.
4. Pick mode: Authorized / Unauthorized / No auth.
5. Paste the required token(s).
6. Click Run Tests; watch the summary cards.
7. Filter for suspicious 2xx on unauth runs.
8. Export CSV / HTML.

LANDING PAGE

Tool UI as shown in API Sentinel



3. APISphere

Manual API client (Postman-style)

USAGE

Use for manual verification, crafting requests, collections, and inspecting responses (JSON, images, PDF preview) after an automated tool finds a lead.

OWASP / SECURITY

Supporting / manual verification tool — not an automated OWASP scanner

FEATURES

- Method + URL with Params sync
- Headers · Auth · Body · Scripts tabs
- Collections & environment variables
- Response Preview (PDF / image)
- Codegen / collection export

KEY POINTS

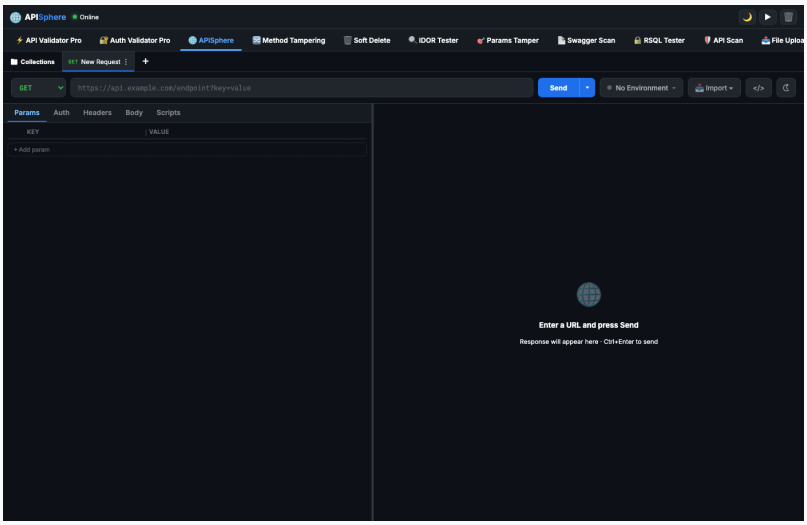
- Ideal follow-up after API Scan / IDOR / Auth Validator findings.
- Query string stays editable in URL and Params (no silent strip).
- Use Scripts for token extract / assert patterns.

USER WORKFLOW (follow in order)

1. Open APISphere.
2. Set HTTP method and full URL (including ?query if any).
3. Fill Headers, Auth, Body, or Params.
4. Optional: save to Collection; set folder/env variables; add Scripts.
5. Click Send.
6. Inspect Status, Headers, Body, and Preview.
7. Export / codegen as needed.

LANDING PAGE

Tool UI as shown in API Sentinel



4. Method Tampering

Alternate HTTP verbs on the same endpoint

USAGE

Use when an API is locked to one method (e.g. POST only) and you want to see if GET/PUT/DELETE/PATCH still work without proper authorization.

OWASP / SECURITY

API5:2023 Broken Function Level Authorization · HTTP verb tampering

FEATURES

- HAR / OpenAPI / AV Capture import
- Selectable alternate methods
- Side-by-side original vs tampered results
- Export support

KEY POINTS

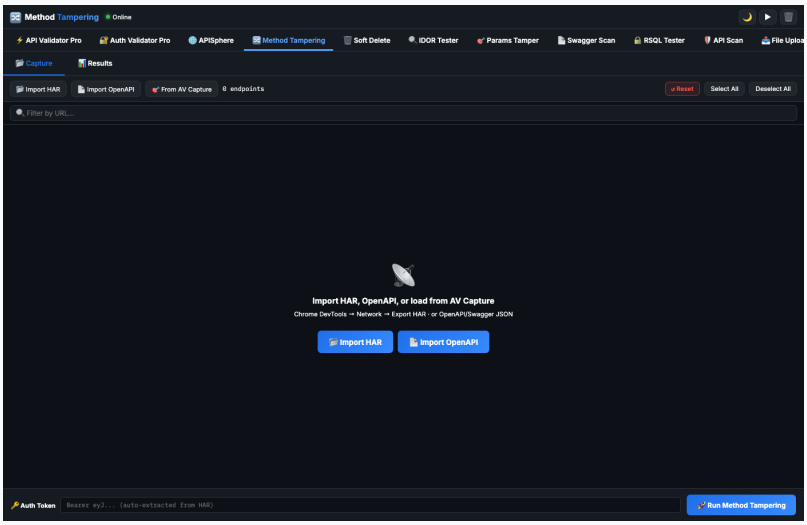
- Unexpected 2xx on a forbidden method is the finding.
- OpenAPI import helps when you have a catalog but no traffic yet.
- Compare body/status against the original method baseline.

USER WORKFLOW (follow in order)

1. Open Method Tampering.
2. Import HAR, OpenAPI/Swagger, or load From Capture.
3. Select endpoints to test.
4. Choose which alternate methods to fire.
5. Run the scan.
6. Review methods that unexpectedly succeed (2xx).
7. Export results.

LANDING PAGE

Tool UI as shown in API Sentinel



5. Soft Delete

Delete then re-read resource checks

USAGE

Use on delete/archive flows to check whether “deleted” objects remain readable, listed, or restorable via ID.

OWASP / SECURITY

API1:2023 BOLA · API3:2023 Excessive Data Exposure · soft-delete / inventory gaps

FEATURES

- HAR / capture import
- Delete + follow-up read/list sequencing
- Status / body comparison after delete
- Export findings

KEY POINTS

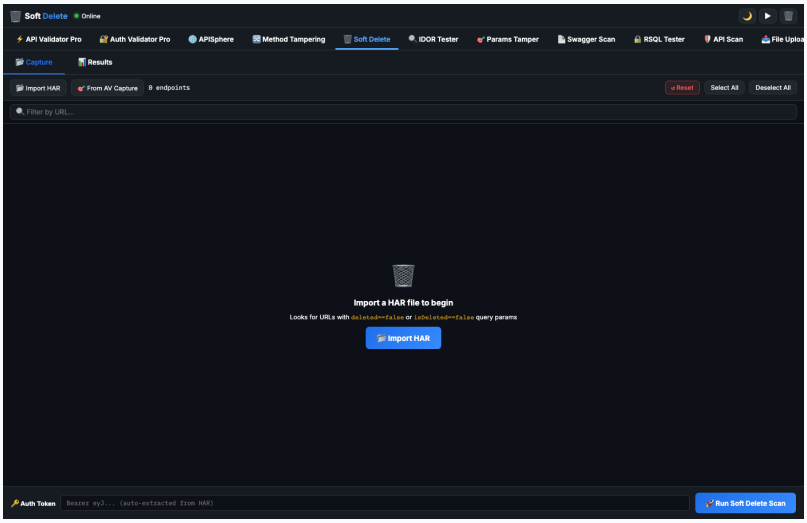
- Map both the DELETE (or soft-delete) call and a GET-by-id / list call.
- 200 + data after delete = soft-delete / authorization issue.
- Confirm with the same auth context the app uses in production.

USER WORKFLOW (follow in order)

1. Open Soft Delete.
2. Import HAR or load from Capture (delete + get/list APIs).
3. Identify delete request and follow-up read/list requests.
4. Run the soft-delete sequence.
5. Check whether deleted IDs still return data (2xx).
6. Export findings.

LANDING PAGE

Tool UI as shown in API Sentinel



6. IDOR Tester

Cross-user object ID swap

USAGE

Use when APIs take resource IDs (path/query/body) and you have two user contexts — swap IDs/tokens to detect Broken Object Level Authorization.

OWASP / SECURITY

API1:2023 Broken Object Level Authorization (BOLA / IDOR)

FEATURES

- HAR / cURL / tool handoff
- User A vs User B tokens
- ID swap in path, query, and body
- Highlighted cross-access hits
- CSV / HTML export

KEY POINTS

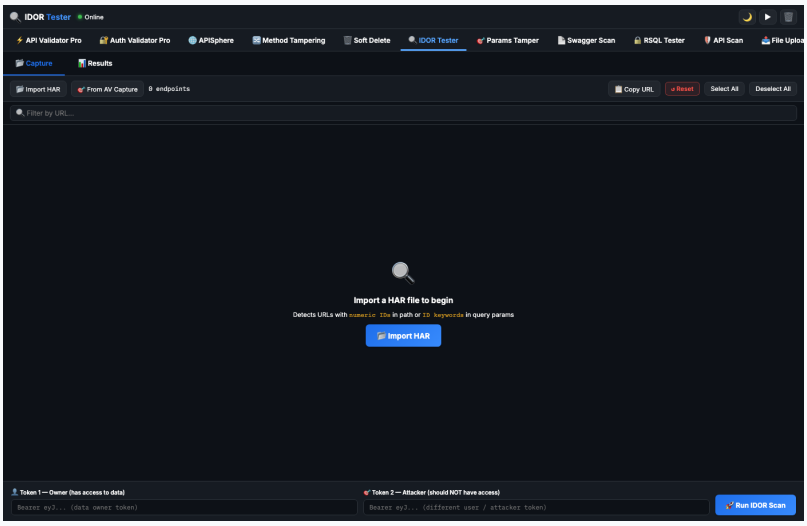
- Need two real accounts (or tokens) for meaningful tests.
- User A token + User B object ID returning B's data = classic IDOR.
- Focus on /users/{id}, /orders/{id}, account, document IDs — not static catalog IDs.

USER WORKFLOW (follow in order)

1. Open IDOR Tester.
2. Import HAR / cURL or receive handoff from another tool.
3. Select requests that contain resource IDs.
4. Paste User A and User B tokens; set IDs to swap.
5. Run IDOR tests.
6. Review cross-user data access cases.
7. Export the report.

LANDING PAGE

Tool UI as shown in API Sentinel



7. Params Tamper

Targeted parameter mutation

USAGE

Use for deep testing of selected parameters with attack/edge datasets when you already know which fields matter.

OWASP / SECURITY

API4:2023 · injection / mass-assignment style abuse · input validation

FEATURES

- Capture / HAR / cURL load
- Param detection + multi-select
- Attack / edge datasets + custom values
- Response diff oriented results
- CSV / HTML export

KEY POINTS

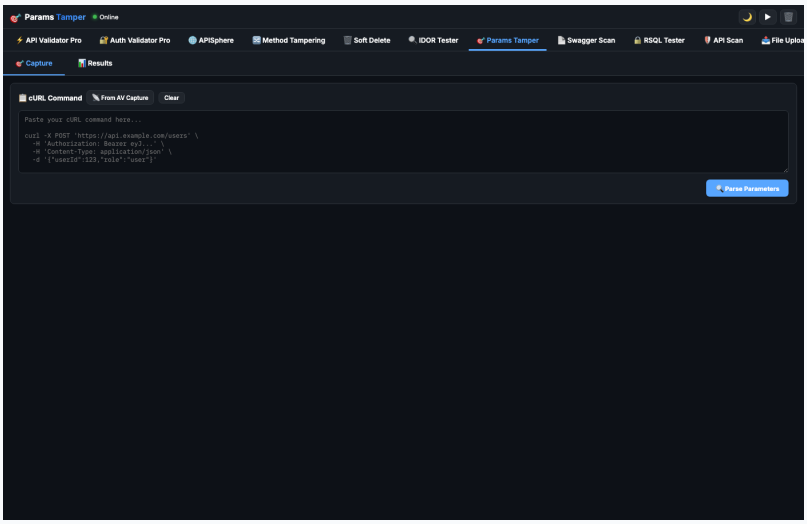
- Narrower than API Validator — pick fewer params, richer payloads.
- Watch for 500s, stack traces, or unexpected 2xx on hostile values.
- Good bridge before launching full API Scan on the same request.

USER WORKFLOW (follow in order)

1. Open Params Tamper.
2. Load a request from Capture, HAR, or cURL.
3. Detect parameters; select which to mutate.
4. Choose dataset / add custom values.
5. Run tamper tests.
6. Compare responses and export.

LANDING PAGE

Tool UI as shown in API Sentinel



8. Swagger Scan

Static OpenAPI / Swagger audit

USAGE

Use when you have an OpenAPI/Swagger file and want a fast inventory of unsecured operations, dangerous-by-name endpoints, and schema/security leads — before live testing.

OWASP / SECURITY

API8:2023 Misconfiguration · API9:2023 Improper Inventory · API3/API6 schema leads · auth gaps in the spec

FEATURES

- JSON / YAML upload (OAS2 + OAS3)
- Unsecured · Dangerous · Sensitive · Mass-assign · Refs · Secrets…
- Strict unsecured (OOScope parity) toggle
- Optional live probe (safe methods)
- Health score · CSV / HTML export

KEY POINTS

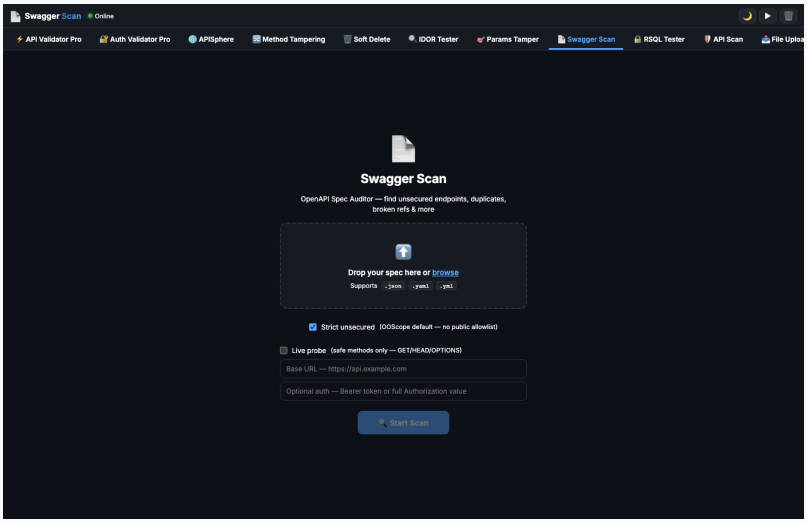
- Strict unsecured ON = OOScope-style list (no public allowlist).
- Findings are from the document — confirm sensitive ones with live tools.
- Live probe needs Base URL; mutating methods use OPTIONS only.

USER WORKFLOW (follow in order)

1. Open Swagger Scan.
2. Upload OpenAPI .json / .yaml / .yml.
3. Leave Strict unsecured ON for OOScope parity (or OFF to allowlist health/login/docs).
4. Optional: enable Live probe + Base URL + auth.
5. Click Start Scan.
6. Walk result sections (Unsecured, Dangerous, Sensitive, …).
7. Export CSV / HTML.

LANDING PAGE

Tool UI as shown in API Sentinel



9. RSQL Tester

RSQL / FIQL filter injection

USAGE

Use on search/list APIs that accept RSQL or FIQL-style filter query parameters to probe injection and filter bypass.

OWASP / SECURITY

Injection via query filters · excessive data exposure / resource abuse

FEATURES

- HAR / AV Capture import
- RSQL-oriented payload set
- Param targeting for filter fields
- Export results

KEY POINTS

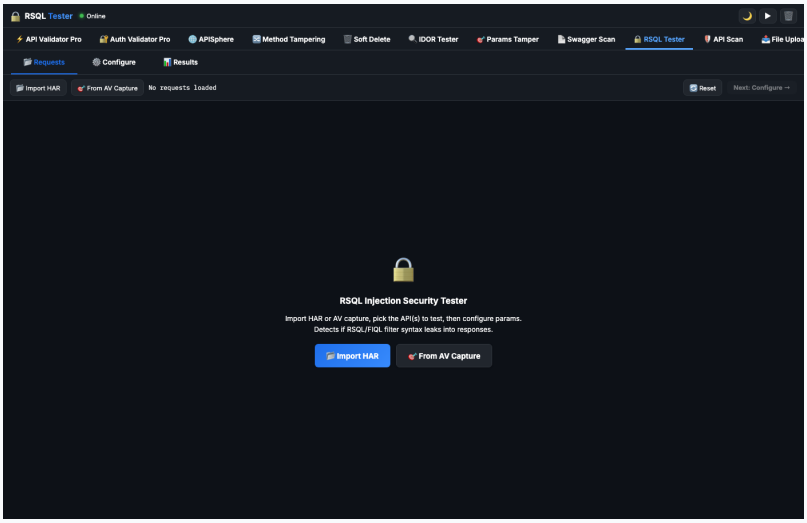
- Look for query params like filter, search, query, rsql, q.
- Unexpected wide result sets or 500s after payloads are leads.
- Confirm sensitive data leakage manually in APISphere.

USER WORKFLOW (follow in order)

1. Open RSQL Tester.
2. Import HAR or AV Capture; select filter-style APIs.
3. Confirm / select the filter parameter(s).
4. Run RSQL payloads.
5. Review anomalous 2xx / errors / oversized responses.
6. Export results.

LANDING PAGE

Tool UI as shown in API Sentinel



10. API Scan

Active multi-module vulnerability scan

USAGE

Use for broad active testing of one or more real requests — SQLi, XSS, SSRF, JWT, IDOR heuristics, SSTI, and more — with live probe streaming.

OWASP / SECURITY

OWASP API Top 10–aligned active probes (module-dependent: API1–API8 style vectors)

FEATURES

- Capture / HAR / Parse cURL intake
- Module / profile selection
- Live probes + issues stream
- Auth pause / resume / skip on 401–403 streaks
- Stop · CSV / HTML export

KEY POINTS

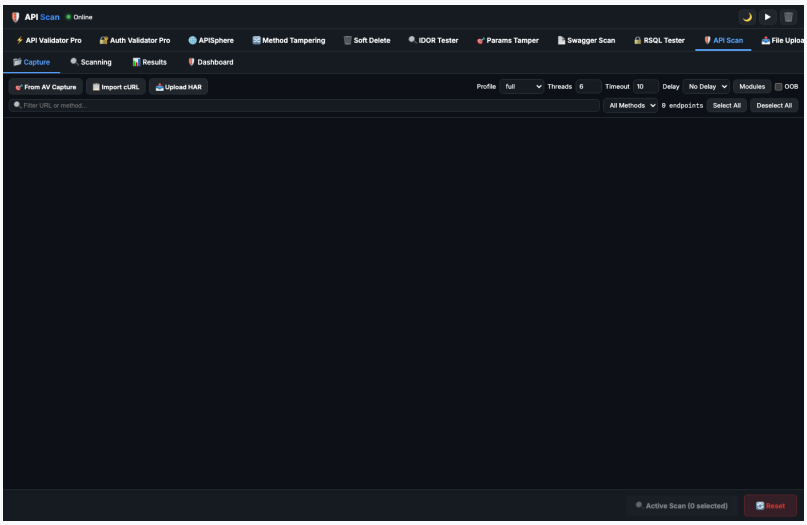
- Heaviest tool — start with a few high-value APIs, not the whole HAR.
- If paused for auth, paste a fresh token or Skip.
- Treat CRITICAL/HIGH as leads; confirm in APISphere before reporting.

USER WORKFLOW (follow in order)

1. Open API Scan.
2. Add targets (Capture handoff, HAR, or Parse cURL).
3. Select modules / profile; keep threads moderate.
4. Click Start Scan.
5. If Auth pause appears → Update token or Skip.
6. Watch live probes/issues; Stop if needed.
7. Open Results → export CSV / HTML.

LANDING PAGE

Tool UI as shown in API Sentinel



11. File Upload

Malicious & edge-case upload suite

USAGE

Use against multipart upload APIs to test type checks, content sniffing, extension tricks, and document-specific attacks (e.g. Excel/OOXML).

OWASP / SECURITY

API8:2023 Misconfiguration · unrestricted / weakly validated file upload

FEATURES

- cURL / HAR / Capture import
- Auto file-field + profile detection
- Polyglot / MIME / extension / path payloads
- Verdicts: Accepted · Rejected · Server error
- CSV / HTML export

KEY POINTS

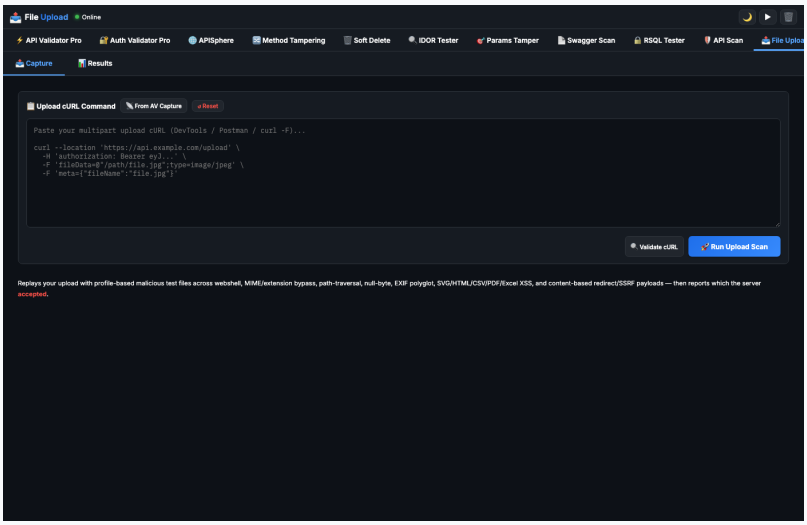
- Baseline valid file should succeed first — then attack suite.
- Accepted malicious type = finding; clean Rejected = control working.
- Match profile to the API (image vs Excel vs generic).

USER WORKFLOW (follow in order)

1. Open File Upload.
2. Import the upload request (cURL / HAR / Capture).
3. Confirm detected file field and profile.
4. Run the upload test suite.
5. Review Accepted / Rejected / Server Error per case.
6. Export CSV / HTML.

LANDING PAGE

Tool UI as shown in API Sentinel



12. XSS Test

Reflected XSS payload probing

USAGE

Use when API responses feed HTML/JS UIs — inject XSS payloads into parameters and check for reflection / unsafe sinks.

OWASP / SECURITY

XSS (CWE-79) · API8:2023 Security Misconfiguration (output encoding)

FEATURES

- Capture / HAR / cURL load
- Param multi-select
- Quick / Full / Reflected profiles
- Reflection highlighting
- CSV / HTML export

KEY POINTS

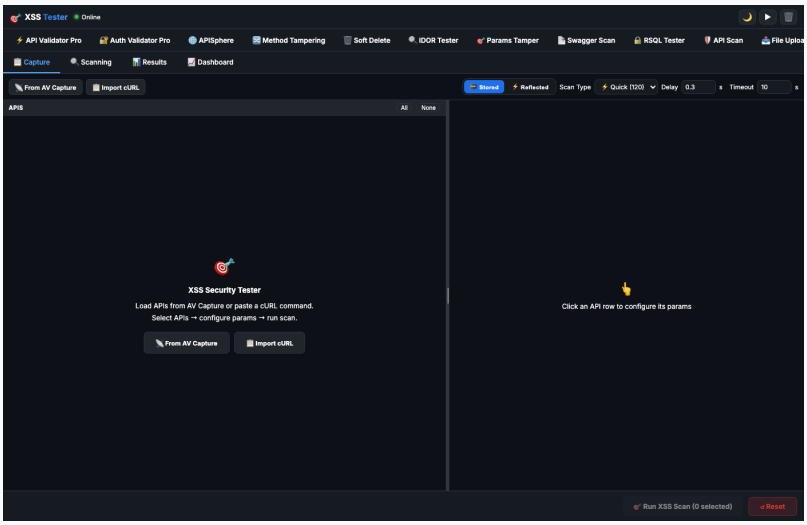
- JSON APIs may reflect strings safely — still check if a web UI renders them raw.
- Reflected profile focuses on echo detection.
- Confirm in browser when the API feeds an HTML page.

USER WORKFLOW (follow in order)

1. Open XSS Test.
2. Load API from Capture / HAR / cURL.
3. Select parameters to inject.
4. Choose Quick, Full, or Reflected profile.
5. Run tests and review reflections.
6. Export findings.

LANDING PAGE

Tool UI as shown in API Sentinel



13. JS Analyser

Secrets · PII · infra in API traffic

USAGE

Use to mine captured responses and bodies for leaked secrets, PII, and optional internal infrastructure indicators.

OWASP / SECURITY

API3:2023 Excessive Data Exposure · secret leakage · sensitive data in responses

FEATURES

- HAR import · live Capture · cURL
- Always-on secret rules; optional PII + infra
- Continuous Start mode or Run selected
- Filterable results table
- HTML export

KEY POINTS

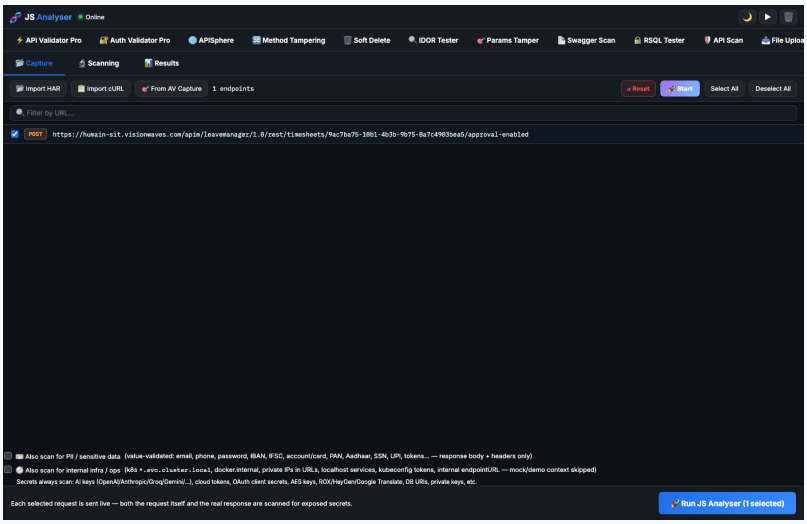
- Secrets scan is always on; enable PII / Infra only when needed (noise control).
- Use Search in expanded request/response to jump matches.
- Treat placeholders / examples carefully — validate before filing.

USER WORKFLOW (follow in order)

1. Open JS Analyser → Capture tab.
2. Import HAR or use live Capture; optional cURL paste.
3. Optional: tick PII and/or Infra.
4. Select endpoints → Run JS Analyser (or Start for continuous).
5. Watch Scanning; open Results.
6. Filter by type / severity; Export HTML.

LANDING PAGE

Tool UI as shown in API Sentinel



14. LLM / Command Injection

OS command + LLM prompt injection fuzzing

USAGE

Use on parameters that may reach a shell or an LLM/prompt pipeline — detect command injection and jailbreak / prompt-injection signals.

OWASP / SECURITY

OS Command Injection (CWE-77/78) · LLM prompt injection / insecure AI handling

FEATURES

- Capture / HAR / cURL intake
- Param selection
- CMDi + LLM jailbreak payload packs
- Baseline-aware confirmation (reduces echo FPs)
- HTML export

KEY POINTS

- Prefer params named cmd, exec, query, prompt, message, input.
- Confirmed hits > heuristic — re-check in APISphere.
- LLM findings often need multi-turn manual follow-up.

USER WORKFLOW (follow in order)

1. Open LLM/Command Injection.
2. Load target request (Capture / HAR / cURL).
3. Select parameters to fuzz.
4. Run the scan.
5. Review confirmed vs heuristic findings.
6. Export HTML report.

LANDING PAGE

Tool UI as shown in API Sentinel

